

Broker password visible in MTAPI Docker logs

Incident report — MTAPI migration bridge (Contabo VPS) · TScopier

Severity	High (credential exposure on shared host)	Status	Open — rotation required; redactor + localhost `:8080` done
Detected	2026-09-23 ~10:17 CEST (user review of container logs)	Reported	2026-09-23
Component	MTAPI Docker bridge (<code>timurila/mt5rest</code> , container <code>mtapi</code>)	Affected users	Demo broker login <code>476205231</code> (test account); risk pattern applies to any MTAPI-linked account
Environment	Contabo VPS <code>13.140.44.122</code> (migration / staging infra)	Root cause	Third-party MTAPI process logs login + password on warning paths

Executive summary (plain English): While checking the MTAPI bridge logs on our server, a broker account password appeared in clear text. The password is not written by TScopier application code. The third-party MTAPI program that talks to MetaTrader prints the account number and password whenever it logs a warning (for example when a symbol name is wrong). Anyone with root access to the server, or anyone who copies these logs into a ticket or chat, could read the password. The safe response is to change the broker password immediately, wipe the old log files, and keep the MTAPI port closed to the public internet. Application code already encrypts stored passwords and strips them from API responses; that path is not the leak.

1. Issue encountered

User ran `docker logs mtapi` on the Contabo VPS and saw the plaintext broker password in a warning line:

```
[08:18:40 WRN] ( '476205231' 'REDACTED' '96.0.46.31' '443' '' '5c6d8eb6-09bb-41b5-b260-73498b725661') <Symbol not found: XAUUSD>
System.Exception: Symbol not found: XAUUSD
    at mtapi.mt5.Symbols.GetInfo(String symbol)
    at mt5rest.MT5.SymbolParams(...) in /src/mt5rest/Controllers/MT5.cs:line 473
```

The same tuple format can appear on other failure paths (for example connect errors). Docker's default `json-file` driver keeps these lines under `/var/lib/docker/containers/*/json.log` until truncated.

Secondary exposure observed in the same log dump: port `8080` on `13.140.44.122` is reachable from the internet and is receiving automated scanner traffic (`/login` , `/board.cgi` , `/GponForm/...` , etc.). The API is also protected by nginx + API key on `443`, but the container port should be firewalled anyway.

2. Affected credential

User	Broker login	Server	Provider	Session id (non-secret)
Test / demo	<code>476205231</code>	Exness-MT5Trial9	mtapi	<code>5c6d8eb6-09bb-41b5-b260-73498b725661</code>

Password value intentionally omitted from this document. Treat it as compromised for the lifetime of the log files on the VPS.

3. Root cause

- Primary:** The `timurila/mt5rest` binary logs connection parameters (`login` , `password` , `ip` , `port` , ...) on WRN/ERR paths. We do not control that source code.
- Contributing:** Docker log driver retains plaintext stdout/stderr on disk with no redaction.
- Contributing:** Port `8080` was not blocked by UFW (known follow-up), increasing the value of the host as a target.
- Not the cause:** TScopier edge/worker stores passwords AES-256-GCM encrypted (`broker_password_encrypted`), strips them via `stripSecrets` , and Sentry redaction already masks `broker_password` . Worker `mtapiProvider` already warns that `ConnectEx` puts the password in the URL query string — nginx access logs were already switched to a redacted format that drops the query string (prior incident).

4. The fix

Immediate (ops — run on the VPS as root):

1. **Rotate the broker password** for login `476205231` in the Exness portal, then reconnect the account in TScopier (Delete + Connect, or Reconnect) so the new password is stored encrypted. *Still open — blocks “Fixed” status.*

2. **Done (2026-09-23):** log redactor installed via `deploy/mtapi-log-redactor/install.sh` — container recreated with `redact.awk` filter; historical json logs for this container truncated.

3. **Done (2026-09-23):** public container port closed by binding `-p 127.0.0.1:8080:80` . External probe of `:8080` now times out; `:9443` remains Healthy. (UFW alone does not block Docker-published ports.)

4. Optionally cap Docker log size for future restarts (`max-size` / `max-file` on the `mtapi` service).

5. After rotation: `docker logs mtapi` must not contain the old password; any credential WRN should show `[REDACTED]` .

Code / process (tracked in PROJECT_MEMORY):

• Never paste full `docker logs mtapi` output into tickets, chat, or repo docs while WRN credential tuples exist.

• Prefer paid MTAPI image with MongoDB and a future upstream change / wrapper that suppresses WRN credential tuples (long term).

• Keep nginx `mtapi_safe` log format (no query string) — already live.

• Re-enable MTAPI IP allowlist once worker egress IP is known and stable.

5. Files / systems touched

System	Change
Contabo VPS / Docker <code>mtapi</code>	Redactor installed + historical logs truncated; public <code>:8080</code> closed (localhost bind) — 2026-09-23
Exness demo login <code>476205231</code>	Password rotation (user action — still open)
<code>deploy/mtapi-log-redactor/</code>	Entrypoint filter package (in-repo, uncommitted)
<code>docs/scratchpads/scratchpad-mtapi-password-in-logs-2026-09-23.md</code>	Investigation notes
<code>docs/incidents/incident-2026-09-23-mtapi-docker-password-logs</code>	This report

Edge / worker application code	No password-logging bug found in TScopier code for this path
--------------------------------	--

6. Verification

- Grep of worker + edge functions: no `console.*` of broker passwords; Sentry redaction covers `broker_password` .
- nginx redacted format already verified in prior incident (no query strings in access log).
- Post-install: container healthy; redactor endpoint active; historical logs truncated. Public `:8080` closed (external probe times out); `:9443` still Healthy.
- Post-rotation checklist (open): new password not present in `docker logs` ; any credential WRN shows `[REDACTED]` .

7. Deployment status

No application deploy required for containment. Redactor installed on VPS; package uncommitted on `migration` . Migration branch Trades/MTAPI UI work continues separately (see PROJECT_MEMORY).

8. Follow-ups

- User rotates password and reconnects (blocking for “Fixed” status).
- Confirm post-rotation logs have no plaintext password; credential WRN shows `[REDACTED]` .
- **Done:** redactor `install.sh` on VPS; public `:8080` closed (localhost bind).
- Long-term: reduce MTAPI container log verbosity / upstream redaction.
- **Done (2026-09-24):** IP allowlist re-enabled — geo filled from access-log worker IPs; `if ($allowed_ip = 0)` active; outsider gets 403, worker stays 200.
- Long-term: reduce MTAPI container log verbosity / upstream redaction.
- Do not treat demo-only exposure as production-safe — same image will host production sessions.